

(a) Modelo de Encuesta Integral sobre Amenazas Persistentes Avanzadas (APT) y Resiliencia Cibernética

Instrucciones generales para la persona encuestada

Esta encuesta está dirigida a responsables de ciberseguridad, riesgo, tecnología o continuidad de negocio de organizaciones con actividad en España.

- El objetivo es medir el grado de exposición, preparación y madurez frente a Amenazas Persistentes Avanzadas (APT), así como la aplicación de métricas e indicadores clave.
- No se solicitan datos personales de empleados; la unidad de análisis es la organización.
- Cuando una pregunta no aplique a su organización, seleccione "No aplica" y, si procede, añada un breve comentario explicativo.
- El tono es serio pero no solemne: se permite algún destello de ironía siempre que no perjudique la veracidad de las respuestas.

Por favor, responda pensando en la situación actual (últimos 12 meses).

Bloque 1. Perfil de la organización

1. Tipo de organización
2. ☐ Administración pública (AGE, autonómica, local)
3. ☐ Empresa privada – gran empresa (>250 empleados)
4. ☐ Empresa privada – pyme (10–249 empleados)
5. ☐ Microempresa (<10 empleados)
6. ☐ Entidad del tercer sector / fundación
7.
☐ Otro (especificar): _____
8.
Sector principal de actividad (marque el más relevante)
9. ☐ Energía
10. ☐ Agua
11. ☐ Transporte
12. ☐ Sanidad
13. ☐ Finanzas / Seguros
14. ☐ TIC / Telecomunicaciones
15. ☐ Industria / Manufactura
16. ☐ Educación / Investigación
17. ☐ Administración pública
18. ☐ Comercio / Distribución
19.
☐ Otro (especificar): _____
20.
Ámbito geográfico de operación
21. ☐ Predominantemente local / regional (dentro de una CCAA)
22. ☐ Nacional (España)
23. ☐ UE /EEE
24.
☐ Global (varios continentes)
25.
Tamaño aproximado de la plantilla
26. ☐ < 50
27. ☐ 50–249
28. ☐ 250–999
29. ☐ 1 000–4 999

30.

☐ $\geq 5\,000$

31.

Figura responsable máxima de ciberseguridad en la organización

32. ☐ CISO / Responsable de Seguridad de la Información

33. ☐ Responsable de TI sin rol específico de seguridad

34. ☐ Responsable de Riesgos / Cumplimiento

35. ☐ No existe un responsable claramente identificado

36. ☐ Otro (especificar): _____

☐ Otro (especificar): _____

Sector principal de actividad (marque el más relevante)

☐ Otro (especificar): _____

Ámbito geográfico de operación

☐ Global (varios continentes)

Tamaño aproximado de la plantilla

☐ $\geq 5\,000$

Figura responsable máxima de ciberseguridad en la organización

Bloque 2. Gobernanza, estrategia y marco normativo

37. Existencia de una estrategia formal de ciberseguridad que incluya explícitamente las APT
38. ☐ Sí, aprobada por el máximo órgano de gobierno (Consejo, Comité de Dirección, etc.)
39. ☐ Sí, pero aprobada solo a nivel de dirección intermedia
40. ☐ En elaboración, prevista aprobación en los próximos 12 meses
41. ☐ No, pero se aplican prácticas dispersas sin documento formal
42. ☐ No existe ni se prevé a corto plazo
43. Alineamiento de la estrategia de ciberseguridad con marcos de referencia reconocidos (puede marcar varias)
44. ☐ NIST CSF 2.0
45. ☐ ISO/IEC 27001
46. ☐ ISO/IEC 27035 (gestión de incidentes)
47. ☐ MITRE ATT&CK (para modelado de amenazas / detección)
48. ☐ ENISA / NIS2 (directiva y guías asociadas)
49. ☐ CCN-STIC (para organismos del sector público español)
50. ☐ Otro (especificar): _____
51. ☐ Ninguno de los anteriores
52. Estado de cumplimiento respecto a NIS2 (si aplica)
53. ☐ Completamente alineados (controles desplegados y operativos)
54. ☐ Parcialmente alineados; existen brechas identificadas y planificadas
55. ☐ En fase inicial de análisis de brechas
56. ☐ No aplica (la organización no se considera entidad esencial o importante)
57. ☐ No se ha evaluado la aplicabilidad de NIS2
58. Periodicidad de revisión de la estrategia y políticas de ciberseguridad
59. ☐ Al menos anual, con reporte al máximo órgano de gobierno
60. ☐ Cada 2–3 años
61. ☐ Solo tras un incidente relevante
62. ☐ Sin periodicidad definida (ad hoc)

63.

☐ No se revisan formalmente

64.

Participación del Consejo de Administración / Alta Dirección en la supervisión de la ciberseguridad

☐ Ciberseguridad es un punto recurrente en el Consejo (≥ 4 veces al año)

☐ Se informa al Consejo 1–3 veces al año

☐ Solo se informa al Consejo tras incidentes graves

☐ No se presenta información de ciberseguridad al Consejo

☐ No aplica (no existe Consejo / órgano equivalente)

☐ No existe ni se prevé a corto plazo

Alineamiento de la estrategia de ciberseguridad con marcos de referencia reconocidos (puede marcar varias)

☐ Ninguno de los anteriores

Estado de cumplimiento respecto a NIS2 (si aplica)

☐ No se ha evaluado la aplicabilidad de NIS2

Periodicidad de revisión de la estrategia y políticas de ciberseguridad

☐ No se revisan formalmente

Participación del Consejo de Administración / Alta Dirección en la supervisión de la ciberseguridad

- ☐ Ciberseguridad es un punto recurrente en el Consejo (≥ 4 veces al año)

- ☐ Se informa al Consejo 1–3 veces al año

- ☐ Solo se informa al Consejo tras incidentes graves

- ☐ No se presenta información de ciberseguridad al Consejo

- ☐ No aplica (no existe Consejo / órgano equivalente)

Bloque 3. Gestión del riesgo APT y métricas estratégicas

65.

La organización dispone de un mapa de riesgos que incluye explícitamente las APT como categoría de riesgo diferenciada

- ☐ Sí, con descripción de escenarios, impacto y probabilidad
- ☐ Sí, pero las APT están diluidas dentro de “ciberataques” genéricos
- ☐ En elaboración
- ☐ No

66.

Frecuencia de actualización del análisis de riesgo de ciberseguridad

- ☐ Al menos anual
- ☐ Cada 2–3 años
- ☐ Solo tras cambios significativos (fusiones, adquisiciones, nuevas líneas de negocio)
- ☐ Solo tras incidentes relevantes
- ☐ No se actualiza de forma sistemática

67.

Uso de métricas clave para monitorizar el riesgo APT

La organización dispone de un mapa de riesgos que incluye explícitamente las APT como categoría de riesgo diferenciada

- ☐ Sí, con descripción de escenarios, impacto y probabilidad
- ☐ Sí, pero las APT están diluidas dentro de “ciberataques” genéricos
- ☐ En elaboración
- ☐ No

Frecuencia de actualización del análisis de riesgo de ciberseguridad

- ☐ Al menos anual
- ☐ Cada 2–3 años
- ☐ Solo tras cambios significativos (fusiones, adquisiciones, nuevas líneas de negocio)
- ☐ Solo tras incidentes relevantes
- ☐ No se actualiza de forma sistemática

Uso de métricas clave para monitorizar el riesgo APT

Para cada métrica indique el nivel de adopción:

Escala:

- 0 = No se utiliza
- 1 = Se mide de forma informal / puntual
- 2 = Se mide de forma sistemática, pero sin objetivos claros
- 3 = Se mide, con objetivos definidos y seguimiento periódico

13.1. Tiempo medio de detección (MTTD) de incidentes

- [] 0
- [] 1
- [] 2
- [] 3

13.2. Tiempo medio de respuesta (MTTR) ante incidentes

- [] 0
- [] 1
- [] 2
- [] 3

13.3. Tiempo medio de parcheo (MTTP) de vulnerabilidades críticas

- [] 0
- [] 1
- [] 2
- [] 3

13.4. Porcentaje de incidentes cuyo vector inicial es phishing

- [] 0
- [] 1
- [] 2
- [] 3

13.5. Número de detecciones de TTPs MITRE ATT&CK asociadas a APT

- [] 0
- [] 1
- [] 2
- [] 3

13.6. Número de incidentes implicando a proveedores / cadena de suministro

- [] 0
- [] 1
- [] 2
- [] 3

68.

Nivel de cuantificación económica del riesgo APT (pérdida esperada anual, escenarios de impacto)

- ☐ Se cuantifica económicamente con metodologías formales (p. ej. FAIR)
- ☐ Se realizan estimaciones numéricas aproximadas
- ☐ Solo se utilizan escalas cualitativas (bajo/medio/alto)
- ☐ No se realiza cuantificación del riesgo

69.

Grado de integración del riesgo APT en la planificación de continuidad de negocio y resiliencia operacional

- ☐ Totalmente integrado (escenarios, umbrales de activación, pruebas)
- ☐ Parcialmente integrado (algunos escenarios o funciones)
- ☐ Mencionado de forma genérica pero sin desarrollo práctico
- ☐ No está integrado

Nivel de cuantificación económica del riesgo APT (pérdida esperada anual, escenarios de impacto)

- ☐ Se cuantifica económicamente con metodologías formales (p. ej. FAIR)
- ☐ Se realizan estimaciones numéricas aproximadas
- ☐ Solo se utilizan escalas cualitativas (bajo/medio/alto)
- ☐ No se realiza cuantificación del riesgo

Grado de integración del riesgo APT en la planificación de continuidad de negocio y resiliencia operacional

- ☐ Totalmente integrado (escenarios, umbrales de activación, pruebas)
- ☐ Parcialmente integrado (algunos escenarios o funciones)
- ☐ Mencionado de forma genérica pero sin desarrollo práctico
- ☐ No está integrado

Bloque 4. Vectores de entrada: phishing, vulnerabilidades y cadena de suministro

70. Detección y gestión del phishing dirigido (spear-phishing / whaling)

En los últimos 12 meses, la organización ha:

- ☐ Sufrido campañas de spear-phishing identificadas y bloqueadas antes de comprometer cuentas
- ☐ Sufrido campañas de spear-phishing con compromiso de al menos una cuenta

- ☐ Realizado simulaciones de phishing internas para concienciación
- ☐ No detectado (o no sabe de) campañas de spear-phishing

71.

Uso de soluciones técnicas específicas contra phishing

- ☐ Filtros avanzados de correo (sandboxing, análisis de enlaces, reputación)
- ☐ Protección del navegador / aislamiento remoto
- ☐ Autenticación fuerte (MFA) sistemática para accesos externos
- ☐ Análisis de contenido generado por IA (detección de deepfakes / anomalías)
- ☐ Ninguna de las anteriores

72.

Gestión del parcheo de vulnerabilidades críticas

Uso de soluciones técnicas específicas contra phishing

- ☐ Filtros avanzados de correo (sandboxing, análisis de enlaces, reputación)
- ☐ Protección del navegador / aislamiento remoto
- ☐ Autenticación fuerte (MFA) sistemática para accesos externos
- ☐ Análisis de contenido generado por IA (detección de deepfakes / anomalías)
- ☐ Ninguna de las anteriores

Gestión del parcheo de vulnerabilidades críticas

En relación con las vulnerabilidades críticas (CVSS $\geq 7,0$) en activos críticos:

- ☐ Se parchea ≥ 95 % en ≤ 7 días
- ☐ Se parchea ≥ 80 % en ≤ 15 días
- ☐ No existe un objetivo temporal formal, pero se parchea “lo antes posible”
- ☐ El parcheo suele demorarse más de 30 días
- ☐ No existe proceso de gestión de vulnerabilidades formalizado

73.

Fuentes de información de amenazas (Threat Intelligence) utilizadas regularmente

- ☐ Boletines de INCIBE / CCN-CERT
- ☐ Informes de ENISA / Agencias europeas
- ☐ Feeds comerciales (proveedores de TI / seguridad)
- ☐ Comunidades de intercambio sectoriales (ISAC, etc.)
- ☐ Fuentes abiertas seleccionadas (p. ej. CERTs internacionales)
- ☐ No se utilizan fuentes específicas de inteligencia de amenazas

74.

Gestión del riesgo en la cadena de suministro digital

Fuentes de información de amenazas (Threat Intelligence) utilizadas regularmente

- ☐ Boletines de INCIBE / CCN-CERT
- ☐ Informes de ENISA / Agencias europeas
- ☐ Feeds comerciales (proveedores de TI / seguridad)
- ☐ Comunidades de intercambio sectoriales (ISAC, etc.)
- ☐ Fuentes abiertas seleccionadas (p. ej. CERTs internacionales)
- ☐ No se utilizan fuentes específicas de inteligencia de amenazas

Gestión del riesgo en la cadena de suministro digital

Respecto a proveedores críticos de TI, cloud y servicios gestionados:

- ☐ Se evalúan sus controles de seguridad antes de la contratación
- ☐ Se incluyen cláusulas específicas de ciberseguridad y notificación de incidentes
- ☐ Se realiza seguimiento periódico (al menos anual) de su postura de seguridad
- ☐ Se exigen certificaciones (ISO 27001, ENS, etc.)
- ☐ No se realiza evaluación estructurada de seguridad de proveedores

Bloque 5. Detección basada en TTPs y MITRE ATT&CK

75.

Uso del marco MITRE ATT&CK en la organización

- ☐ Utilizado para modelar amenazas y priorizar casos de uso de detección
- ☐ Utilizado para evaluar cobertura de detección en SOC / SIEM
- ☐ Utilizado solo de manera informal / ad hoc
- ☐ Conocido pero no utilizado
- ☐ Desconocido hasta el momento (pero ya no, gracias a esta encuesta)

76.

Cobertura de técnicas MITRE relevantes para APT

Uso del marco MITRE ATT&CK en la organización

- ☐ Utilizado para modelar amenazas y priorizar casos de uso de detección
- ☐ Utilizado para evaluar cobertura de detección en SOC / SIEM
- ☐ Utilizado solo de manera informal / ad hoc
- ☐ Conocido pero no utilizado
- ☐ Desconocido hasta el momento (pero ya no, gracias a esta encuesta)

Cobertura de técnicas MITRE relevantes para APT

Indique el nivel de capacidad de detección (0–3) para las siguientes técnicas:

Escala:

- 0 = No se detecta
- 1 = Se detecta de forma limitada / manual
- 2 = Se detecta de forma automatizada para parte del entorno
- 3 = Se detecta de forma automatizada y se correlaciona con otros eventos

22.1. System Information Discovery (recopilación de info del sistema)

- ☐ 0
- ☐ 1
- ☐ 2
- ☐ 3

22.2. Ingress Tool Transfer (transferencia de herramientas al entorno comprometido)

- ☐ 0
- ☐ 1
- ☐ 2
- ☐ 3

22.3. Web Protocols (uso de protocolos web para C2)

- ☐ 0
- ☐ 1
- ☐ 2
- ☐ 3

22.4. Credencial Access (robo de credenciales)

- ☐ 0
- ☐ 1
- ☐ 2
- ☐ 3

22.5. Lateral Movement (movimiento lateral)

- ☐ 0
- ☐ 1
- ☐ 2
- ☐ 3

77.

Existencia de un plan de detección específico para APT

- ☐ Sí, con casos de uso definidos y playbooks asociados
- ☐ Sí, pero integrado dentro del plan general de detección de amenazas
- ☐ En elaboración
- ☐ No existe

78.

Uso de análisis avanzado (IA / ML) en detección de patrones APT

- ☐ Se utilizan modelos de IA/ML entrenados con datos propios
- ☐ Se utilizan modelos incluidos en soluciones comerciales (EDR, NDR, XDR, etc.)
- ☐ Se encuentran en fase piloto / prueba de concepto
- ☐ No se utilizan técnicas de IA/ML en detección

Existencia de un plan de detección específico para APT

- ☐ Sí, con casos de uso definidos y playbooks asociados
- ☐ Sí, pero integrado dentro del plan general de detección de amenazas
- ☐ En elaboración
- ☐ No existe

Uso de análisis avanzado (IA / ML) en detección de patrones APT

- ☐ Se utilizan modelos de IA/ML entrenados con datos propios
- ☐ Se utilizan modelos incluidos en soluciones comerciales (EDR, NDR, XDR, etc.)
- ☐ Se encuentran en fase piloto / prueba de concepto
- ☐ No se utilizan técnicas de IA/ML en detección

Bloque 6. Respuesta a incidentes y recuperación

79.

Existencia de un Plan de Respuesta a Incidentes (PRI)

- ☐ Sí, documentado y alineado con estándares (p. ej. ISO 27035)
- ☐ Sí, pero informal / sin alineamiento explícito
- ☐ En elaboración
- ☐ No existe

80.

Pruebas y simulacros de respuesta a incidentes APT

- ☐ Se realizan ejercicios de mesa (table-top) al menos una vez al año
- ☐ Se realizan simulaciones técnicas (red team, purple team, etc.)
- ☐ Se han realizado pruebas puntuales pero sin periodicidad definida
- ☐ No se han realizado pruebas específicas para APT

81.

Métricas operativas de respuesta

Existencia de un Plan de Respuesta a Incidentes (PRI)

- ☐ Sí, documentado y alineado con estándares (p. ej. ISO 27035)
- ☐ Sí, pero informal / sin alineamiento explícito
- ☐ En elaboración
- ☐ No existe

Pruebas y simulacros de respuesta a incidentes APT

- ☐ Se realizan ejercicios de mesa (table-top) al menos una vez al año
- ☐ Se realizan simulaciones técnicas (red team, purple team, etc.)
- ☐ Se han realizado pruebas puntuales pero sin periodicidad definida
- ☐ No se han realizado pruebas específicas para APT

Métricas operativas de respuesta

Indique el nivel de madurez (0–3) para cada métrica:

- 0 = No se mide
 - 1 = Se mide pero no se revisa regularmente
 - 2 = Se mide y se revisa periódicamente
 - 3 = Se mide, se revisa y se utilizan umbrales/SLAs de mejora
- 27.1. MTTR desde detección hasta contención
- ☐ 0
 - ☐ 1
 - ☐ 2
 - ☐ 3
- 27.2. MTTR desde contención hasta erradicación
- ☐ 0
 - ☐ 1
 - ☐ 2
 - ☐ 3
- 27.3. Tiempo hasta la comunicación interna al máximo órgano de gobierno
- ☐ 0
 - ☐ 1
 - ☐ 2
 - ☐ 3
- Coordinación con organismos externos en caso de incidentes graves
- ☐ Se coordinan acciones con INCIBE / CCN-CERT / Fuerzas y Cuerpos de Seguridad
 - ☐ Se notifica a proveedores críticos y reguladores sectoriales cuando aplica
 - ☐ No existen protocolos formales de coordinación externa
 - ☐ No se han considerado aún estos aspectos

3 = Se mide, se revisa y se utilizan umbrales/SLAs de mejora

27.1. MTTR desde detección hasta contención

- ☐ 0
- ☐ 1
- ☐ 2
- ☐ 3

27.2. MTTR desde contención hasta erradicación

- ☐ 0
- ☐ 1
- ☐ 2
- ☐ 3

27.3. Tiempo hasta la comunicación interna al máximo órgano de gobierno

- ☐ 0
- ☐ 1
- ☐ 2
- ☐ 3

Coordinación con organismos externos en caso de incidentes graves

- ☐ Se coordinan acciones con INCIBE / CCN-CERT / Fuerzas y Cuerpos de Seguridad
- ☐ Se notifica a proveedores críticos y reguladores sectoriales cuando aplica
- ☐ No existen protocolos formales de coordinación externa
- ☐ No se han considerado aún estos aspectos

Bloque 7. Formación, cultura y reporte

82.

Programa de formación y concienciación en ciberseguridad

- ☐ Formación obligatoria anual para todo el personal
- ☐ Formación específica para colectivos de alto riesgo (dirección, finanzas, admins de sistemas)
- ☐ Simulaciones de phishing periódicas con retroalimentación personalizada
- ☐ Solo comunicaciones puntuales (boletines, correos)
- ☐ No existe un programa estructurado de formación

83.

Canales de reporte interno de incidentes o sospechas de phishing

- ☐ Botón/report funcional en el cliente de correo
- ☐ Buzón específico de seguridad (seguridad@..., etc.)
- ☐ Canal anónimo de denuncia
- ☐ Reporte informal al equipo de TI
- ☐ No existe un canal claramente establecido

84.

Número aproximado de reportes de phishing por cada 1 000 empleados al año

- ☐ < 10
- ☐ 10–49
- ☐ 50–99
- ☐ 100–199
- ☐ ≥ 200
- ☐ No se mide / se desconoce

85.

Percepción interna de la ciberseguridad como prioridad estratégica

- ☐ Alta – tema recurrente en foros de dirección y en comunicación interna
- ☐ Media – considerada importante pero compitiendo con otras prioridades
- ☐ Baja – se percibe como coste o requisito impuesto
- ☐ Muy baja – “solo importa cuando algo se rompe”

Programa de formación y concienciación en ciberseguridad

- ☐ Formación obligatoria anual para todo el personal
- ☐ Formación específica para colectivos de alto riesgo (dirección, finanzas, admins de sistemas)
- ☐ Simulaciones de phishing periódicas con retroalimentación personalizada
- ☐ Solo comunicaciones puntuales (boletines, correos)
- ☐ No existe un programa estructurado de formación

Canales de reporte interno de incidentes o sospechas de phishing

- ☐ Botón/report funcional en el cliente de correo
- ☐ Buzón específico de seguridad (seguridad@..., etc.)
- ☐ Canal anónimo de denuncia
- ☐ Reporte informal al equipo de TI
- ☐ No existe un canal claramente establecido

Número aproximado de reportes de phishing por cada 1 000 empleados al año

- ☐ < 10
- ☐ 10–49
- ☐ 50–99
- ☐ 100–199
- ☐ ≥ 200
- ☐ No se mide / se desconoce

Percepción interna de la ciberseguridad como prioridad estratégica

- ☐ Alta – tema recurrente en foros de dirección y en comunicación interna
- ☐ Media – considerada importante pero compitiendo con otras prioridades
- ☐ Baja – se percibe como coste o requisito impuesto
- ☐ Muy baja – “solo importa cuando algo se rompe”

Bloque 8. Inversión, ROI y priorización (IGM)

86.

Nivel aproximado de inversión anual en ciberseguridad (% del presupuesto de TI)

- ☐ < 5 %
- ☐ 5–9 %
- ☐ 10–14 %
- ☐ ≥ 15 %
- ☐ Desconocido / no se desglosa a este nivel

87.

Existencia de un modelo de medición del Retorno de la Inversión (ROI) en ciberseguridad

- ☐ Sí, se estima el ROI con base en reducción de pérdidas esperadas / incidentes evitados
- ☐ Sí, pero de forma parcial o experimental
- ☐ No, pero se está analizando implantarlo
- ☐ No, y no se considera prioritario

88.

Uso de un Índice Global de Madurez (IGM) en ciberseguridad

- ☐ Sí, con metodología formal, escalas y objetivos
- ☐ Sí, pero de forma informal (puntuaciones internas sin metodología documentada)
- ☐ No, pero se está valorando
- ☐ No se utiliza ni se prevé utilizar un IGM

89.

Influencia de incidentes recientes (propios o de terceros) en el aumento de la inversión

- ☐ La inversión ha aumentado claramente tras incidentes recientes propios
- ☐ La inversión ha aumentado tras incidentes mediáticos en el sector
- ☐ La inversión se ha mantenido estable independientemente de los incidentes
- ☐ La inversión se ha reducido

Nivel aproximado de inversión anual en ciberseguridad (% del presupuesto de TI)

- ☐ < 5 %
- ☐ 5–9 %
- ☐ 10–14 %
- ☐ ≥ 15 %
- ☐ Desconocido / no se desglosa a este nivel

Existencia de un modelo de medición del Retorno de la Inversión (ROI) en ciberseguridad

- ☐ Sí, se estima el ROI con base en reducción de pérdidas esperadas / incidentes evitados
- ☐ Sí, pero de forma parcial o experimental
- ☐ No, pero se está analizando implantarlo
- ☐ No, y no se considera prioritario

Uso de un Índice Global de Madurez (IGM) en ciberseguridad

- ☐ Sí, con metodología formal, escalas y objetivos
- ☐ Sí, pero de forma informal (puntuaciones internas sin metodología documentada)
- ☐ No, pero se está valorando
- ☐ No se utiliza ni se prevé utilizar un IGM

Influencia de incidentes recientes (propios o de terceros) en el aumento de la inversión

- ☐ La inversión ha aumentado claramente tras incidentes recientes propios
- ☐ La inversión ha aumentado tras incidentes mediáticos en el sector
- ☐ La inversión se ha mantenido estable independientemente de los incidentes
- ☐ La inversión se ha reducido

Bloque 9. Colaboración, ejercicios conjuntos y lecciones aprendidas

90.

Participación en ejercicios conjuntos con otros actores (públicos o privados)

- ☐ Ejercicios sectoriales organizados por reguladores o asociaciones
- ☐ Ejercicios organizados por INCIBE / CCN-CERT
- ☐ Ejercicios bilaterales con proveedores clave
- ☐ No se participa en ejercicios conjuntos

91.

Frecuencia de campañas de prueba (red team / purple team) enfocadas en APT

- ☐ Al menos anual
- ☐ Cada 2–3 años
- ☐ Solo tras incidentes relevantes
- ☐ No se realizan este tipo de ejercicios

92.

Gestión de lecciones aprendidas tras incidentes o simulacros

- ☐ Se documentan, se asignan acciones y se verifican cierres
- ☐ Se documentan parcialmente, sin seguimiento sistemático
- ☐ Se comparten informalmente, sin registro formal
- ☐ No se gestionan de manera estructurada

Participación en ejercicios conjuntos con otros actores (públicos o privados)

- ☐ Ejercicios sectoriales organizados por reguladores o asociaciones
- ☐ Ejercicios organizados por INCIBE / CCN-CERT
- ☐ Ejercicios bilaterales con proveedores clave
- ☐ No se participa en ejercicios conjuntos

Frecuencia de campañas de prueba (red team / purple team) enfocadas en APT

- ☐ Al menos anual
- ☐ Cada 2–3 años
- ☐ Solo tras incidentes relevantes
- ☐ No se realizan este tipo de ejercicios

Gestión de lecciones aprendidas tras incidentes o simulacros

- ☐ Se documentan, se asignan acciones y se verifican cierres
- ☐ Se documentan parcialmente, sin seguimiento sistemático
- ☐ Se comparten informalmente, sin registro formal
- ☐ No se gestionan de manera estructurada

Bloque 10. Visión de futuro

93.

Expectativas sobre la evolución de las APT en los próximos 3 años

- ☐ Aumento significativo en volumen y sofisticación
- ☐ Aumento moderado
- ☐ Estabilidad relativa
- ☐ Disminución (optimismo antropológico)

94.

Prioridades de inversión para mejorar la defensa frente a APT (marque hasta 3)

- ☐ Refuerzo de capacidades de detección (SOC, SIEM, EDR/XDR, NDR)
- ☐ Mejora de la gestión de vulnerabilidades y parcheo
- ☐ Fortalecimiento de la cadena de suministro digital
- ☐ Programas de concienciación y cultura de seguridad
- ☐ Automatización de respuesta (SOAR, playbooks, orquestación)
- ☐ Inteligencia de amenazas específica para APT
- ☐ Refuerzo de continuidad de negocio y recuperación ante desastres
- ☐ Otros (especificar): _____

95.

Comentario abierto

Expectativas sobre la evolución de las APT en los próximos 3 años

- ☐ Aumento significativo en volumen y sofisticación
- ☐ Aumento moderado
- ☐ Estabilidad relativa
- ☐ Disminución (optimismo antropológico)

Prioridades de inversión para mejorar la defensa frente a APT (marque hasta 3)

- ☐ Refuerzo de capacidades de detección (SOC, SIEM, EDR/XDR, NDR)
- ☐ Mejora de la gestión de vulnerabilidades y parcheo
- ☐ Fortalecimiento de la cadena de suministro digital
- ☐ Programas de concienciación y cultura de seguridad
- ☐ Automatización de respuesta (SOAR, playbooks, orquestación)
- ☐ Inteligencia de amenazas específica para APT
- ☐ Refuerzo de continuidad de negocio y recuperación ante desastres
- ☐ Otros (especificar): _____

Comentario abierto

Utilice este espacio para expresar cualquier reflexión adicional, frustración catártica o propuesta visionaria sobre la situación de su organización frente a las APT.

Gracias por su tiempo y por contribuir, al menos durante unos minutos, a que el universo de la ciberseguridad sea un poco más medible y un poco menos caótico.